Republic of the Philippines
POLYTECHNIC UNIVERSITY OF THE PHILIPPINES
SAN PEDRO CAMPUS
PUP, Main Road, Barangay United Bayanihan, City of San Pedro, Laguna

Batumbakal-Gym Database Roles and Privileges

Activity 4 Progress Documentation

1. Introduction

This document presents the progress of Activity 4: Database Users, Roles, Privileges, and Access Control for Group 09 – Batumbakal Gym.

The activity focuses on inspecting the PostgreSQL database, identifying existing user roles, checking assigned privileges, and testing access restrictions. It also evaluates the current database configuration based on the principle of least privilege.

2. Project Overview

Batumbakal Gym is a gym management system that uses PostgreSQL 18 as its database management system.

Project Name	Batumbakal Gym
Database	grp99_gymdb
Schema	public
DBMS	PostgreSQL 18
Backend	Java 25 – Spring Boot 4.1.2
Database Owner	postgres
Application Database Account	postgres

The database stores information related to gym members, trainers, classes, memberships, payments, and attendance. The application currently connects to the database using the postgres account.

3. Database Inspection

The database structure was inspected before checking its access-control configuration.

The inspection confirmed the following:

Database Component	Number
Application Schema	1
Tables	8
Sequences	7

The application schema contains the following tables:

Table Name	Description
attendance	Stores gym attendance records.
class_enrollments	Stores member class enrollment records.
classes	Stores gym class information.
members	Stores gym member information.
membership_plans	Stores available membership plans.
memberships	Stores member membership records.
payments	Stores payment records.
trainers	Stores trainer information.

The database itself is owned by postgres. The inspected application tables and sequences are located in the public schema.

4. Role Creation and Configuration

The existing PostgreSQL roles were inspected to identify their login capabilities and responsibilities.

The inspection identified the following relevant accounts and roles:

Role Name	Login Capability	Description
postgres	LOGIN	PostgreSQL superuser used by the application to connect to the database.
activity4_test_role	NOLOGIN	Existing test role used to check restricted database access.
gym_app	Not Found	Application role mentioned in the project's role documentation but not found during inspection.
gym_readonly	Not Found	Read-only role mentioned in the project's role documentation but not found during inspection.

The postgres account has superuser privileges, including the ability to create databases and roles. The application currently uses this account instead of a dedicated application account.

The inspection also confirmed that gym_app and gym_readonly were not present in the PostgreSQL roles checked. No membership records involving these two roles were found.

The activity4_test_role account was configured as a NOLOGIN role with restricted privileges. It was used for access-control testing to verify whether database operations would be denied when the required permissions were not assigned.

5. Privilege Assignment

The existing PostgreSQL privileges were inspected to determine the permissions assigned to the application account and the test role.

5.1 Database and Schema Privileges

The postgres account has the following database privileges on grp99_gymdb:

- CONNECT
- CREATE
- TEMPORARY

The activity4_test_role account has CONNECT permission but does not have CREATE or TEMPORARY privileges.

For the public schema, the test role has USAGE permission but does not have CREATE permission.

5.2 Table Privileges

The postgres account has SELECT, INSERT, UPDATE, and DELETE privileges on all eight application tables.

Meanwhile, the activity4_test_role account does not have any of these privileges on the eight tables.

5.3 Sequence Privileges

The activity4_test_role account does not have USAGE or SELECT privileges on the seven sequences inspected in the public schema.

No additional sequence privileges were granted to this test role during the inspection.

5.4 Group Roles

The inspection did not identify the gym_app and gym_readonly roles in the PostgreSQL role list.

The existing activity4_test_role was used to test restricted access. No new group roles were created during the inspection.

5.5 Default Privileges

No default-privilege inspection result was recorded in the tests completed so far. Therefore, the default privileges for future tables and sequences are not yet confirmed.

6. Access Control Testing

The existing database accounts were tested to verify whether their assigned privileges allowed or restricted specific database operations.

6.1 Application Database Account

The postgres account was identified as the database account used by the Batumbakal Gym application.

Operation	Expected Result	Actual Result
SELECT from application tables	Allowed	Allowed
INSERT into application tables	Allowed	Allowed
UPDATE application tables	Allowed	Allowed
DELETE from the application tables	Allowed	Allowed

The privilege inspection confirmed that postgres has all four tested table privileges on the eight application tables.

6.2 Test Role Accout

The existing activity4_test_role was used to verify restricted database access.

The following operations were attempted:

Operation	Expected Result	Actual Result
CONNECT to database	Allowed	Successful
SELECT from members	Denied	Permission denied
INSERT into members	Denied	Permission denied
UPDATE members	Denied	Permission denied
DELETE from members	Denied	Permission denied

The UPDATE and DELETE statements used WHERE 1=0 to avoid modifying existing records. The operations were denied because the test role did not have the required table privileges.

6.3 Schema Owner Account

The sequence privileges of activity4_test_role were also inspected.

The results confirmed that the role does not have USAGE or SELECT privileges on the seven sequences in the public schema.

6.4 Testing Summary

The access-control inspection and tests confirmed the following:

- The application connects to PostgreSQL using the postgres superuser account.
- The postgres account has SELECT, INSERT, UPDATE, and DELETE privileges on all eight application tables.
- The activity4_test_role can connect to the database.
- The test role cannot read or modify the members table.
- The test role does not have the inspected sequence privileges.
- The denied operations did not modify existing records.

6.5 Application Integration Testing

The Batumbakal Gym website was opened and inspected through the running application.

The website provides direct access to the dashboard without requiring a login. No application-level authentication or role-based access control was identified during the inspection.

The database connection was also observed through PostgreSQL activity inspection, which showed connections from the PostgreSQL JDBC Driver using the postgres account.

7. Issues and Limitations

During the database inspection and access-control testing, several setup considerations and limitations were identified.

7.1 Application Database Account

The application currently uses the postgres account to connect to the database.

Since postgres is a superuser, the application connection has broader privileges than normally required for regular application operations.

Recommendation: Use a dedicated application account with only the database, schema, table, and sequence privileges required by the system.

7.2 Missing Application Database Roles

The gym_app and gym_readonly roles were mentioned in the project's role documentation but were not found during the PostgreSQL inspection.

Recommendation: Review the role configuration and create the required accounts or roles if they are still part of the intended access-control design.

7.3 Restricted Test Role

The existing activity4_test_role successfully connected to the database but was denied access to the application tables and sequences.

This confirmed that the role has restricted access under the inspected configuration.

7.4 Default Privileges

The pg_default_acl catalog was inspected to check whether customized default privileges were configured for the database.

The query returned zero rows for the global scope and the public schema.

This indicates that no customized default-privilege entries were found for the inspected scopes. Future database objects will follow PostgreSQL's default privilege behavior unless additional default privileges are configured.

8. Evidence and Repository

The SQL script and supporting screenshots for the Group 2 access-control inspection are stored in the group's Car Rental Management System repository under db-access-control/Group02/

Repository links:

- **Repository:** https://github.com/123airabels/Car_Rental_Management_System

- **Pawpaw access-control folder:** Car_Rental_Management_System/db-access-control/Group09 at main · 123airabels/Car_Rental_Management_System
- **SQL script:** Car_Rental_Management_System/db-access-control/Group09/Group9-roles-and-privileges.sql at main · 123airabels/Car_Rental_Management_System
- **Evidence folder:** Car_Rental_Management_System/db-access-control/Group09/Evidence at main · 123airabels/Car_Rental_Management_System

8.1 Evidence Screenshots

The evidence screenshots cover the following database configurations and tests:

Evidence	Description
Database structure	Shows the application database, schema, tables, and sequences.
PostgreSQL roles	Shows the existing database roles and their attributes.
Application Database User	Shows the database account used by the application.
Database Privileges	Shows the database privileges assigned to the inspected roles.
Schema Privileges	Shows USAGE and CREATE permissions on the public schema.
Application Table Privileges	Shows SELECT, INSERT, UPDATE, and DELETE permissions on application tables.
Test Role Privileges	Shows the table privileges of activity4_test_role.
Sequence Privileges	Shows the sequence permissions of the test role.
Default Privileges Inspection	Shows the zero-row result from the pg_default_acl inspection.
Denied Read Access	Shows the permission-denied result when selecting from members.

Denied Insert Access	Shows the permission-denied result when inserting into members.
Denied Update Access	Shows the permission-denied result when updating members.
Denied Delete Access	Shows the permission-denied result when deleting from members.

8.2 Evidence Organization

The screenshots will be organized into three folders:

1. 01. Database Object Inspection Summary
2. 02. Role and Privilege Inspection
3. 03. Runtime Access Testing

These folders separate the database structure, privilege configuration, and actual access-control test results.

8.3 GitHub Upload

The access-control documentation, SQL inspection scripts, and supporting screenshots will be organized under the Group 09 directory before publication to the project repository.

9. SQL Scripts Summary

SQL queries were executed using PostgreSQL to inspect the Batumbakal Gym database and verify its access-control configuration. These included queries for checking the database owner, schema, tables, sequences, existing roles, role memberships, and database, schema, table, and sequence privileges.

The pg_default_acl catalog was also inspected to check for customized default privileges. The query returned zero rows for the global scope and public schema.

The activity4_test_role was used for access-control testing. SELECT, INSERT, UPDATE, and DELETE operations on the members table were all denied due to insufficient privileges. No existing records were modified during these tests.

10. Verification Results

The database roles and privileges were checked using PostgreSQL inspection queries and direct access-control tests.

10.1 Application Database Account Verification

Verification Item	Expected Result	Actual Result
Connect to database	Allowed	Successful
SELECT privileges	Allowed	Privileges confirmed
INSERT privileges	Allowed	Privileges confirmed
UPDATE privileges	Allowed	Privileges confirmed
DELETE privileges	Allowed	Privileges confirmed

Account: postgres

The application database account successfully connected to the database. Inspection queries also confirmed that it has SELECT, INSERT, UPDATE, and DELETE privileges on all eight application tables.

10.2 Additional Privilege Verification

The following configurations were also checked:

- The postgres account has the LOGIN attribute and superuser privileges.
- The activity4_test_role has the NOLOGIN attribute.
- The gym_app and gym_readonly roles were not found.
- The postgres account has CONNECT, CREATE, and TEMPORARY privileges on the database.
- The activity4_test_role has CONNECT permission on the database.
- The activity4_test_role has USAGE but not CREATE permission on the public schema.

- The activity4_test_role has no SELECT, INSERT, UPDATE, or DELETE privileges on the eight application tables.
- The activity4_test_role has no USAGE or SELECT privileges on the seven sequences.
- No customized default-privilege entries were found for the global scope and public schema.
-

These results confirmed the existing database access-control configuration of Batumbakal Gym.

10.3 Additional Security Verification

Additional tests were conducted using activity4_test_role to verify that restricted table operations would be denied.

Test Account	Operation	Expected Result	Actual Result
activity4_test_role	SELECT members	Denied	Permission denied
activity4_test_role	INSERT members	Denied	Permission denied
activity4_test_role	UPDATE members	Denied	Permission denied
activity4_test_role	DELETE members	Denied	Permission denied

The tests confirmed that the restricted test role cannot read or modify records in the members table because it lacks the required privileges.

These results demonstrate the difference between the unrestricted application database account and the restricted test role.

11. Issues and Fixes

Several application and database issues were identified during testing. The findings were reviewed by the owning group, which provided explanations and proposed fixes for each issue.

Issue Found	Owner's Response / Action Taken	Verification Result
Unrevoked PUBLIC Database CONNECT	Revoked PUBLIC CONNECT on the lab	The application and reporting roles reconnected

12.

Privilege – The PUBLIC role could connect to grp99_gymdb, allowing unauthorized accounts to consume connection slots.	database, retained access for authorized roles, and ended nine test sessions.	successfully, while the unlisted role was denied.
Unrestricted DELETE Privileges on gym_app – The application account had DELETE privileges across production tables.	The DELETE grants were recorded as a separate access-control concern for review.	The available response did not confirm that the DELETE privileges were revoked.
Sequence Exhaustion through setval() – The gym_app account could modify sequences and potentially reach the 32-bit SERIAL limit.	Restarted the sequence at the next available ID and revoked sequence UPDATE while retaining USAGE.	A test insert generated ID 6, and attempts to use setval() were denied.
Missing Foreign Key Indexes – Some foreign key columns lacked indexes, potentially slowing database queries.	Refreshed statistics, reviewed query plans, and added an index to attendance.member_id.	The query changed from a sequential scan to an index-backed scan, with median execution time improving from 45.419 ms to 0.532 ms.

Feedback to the Owning Group

The following observations and recommendations were based on the reported database issues:

Area	Feedback / Recommendation
Database Connections	Keep PUBLIC CONNECT revoked and allow only authorized database roles.
DELETE Privileges	Review and limit DELETE permissions to prevent unnecessary bulk deletion.
Sequence Security	Retain USAGE for normal inserts and restrict sequence UPDATE.
Database Performance	Add appropriate indexes to frequently used foreign key columns.

The owning group addressed several reported issues through privilege changes, sequence adjustments, and indexing. However, the DELETE privilege concern still requires further review.

13. AI Usage Declaration

ChatGPT was used as a supplementary tool to help understand PostgreSQL roles, privileges, and access control. It also assisted in reviewing SQL queries, explaining errors, preparing verification queries, and organizing the documentation.

The database configuration, query results, access-control tests, and screenshots were based on the actual Batumbakal Gym project environment. The group reviewed the information and used the actual results as the basis for this documentation.

14. Conclusion

The group successfully inspected and tested the existing database access-control configuration of Batumbakal Gym using PostgreSQL. The activity covered database roles, database and schema privileges, table permissions, sequence privileges, and customized default privileges.
Testing confirmed that the application uses the postgres account, which has extensive database privileges. The group also verified that the activity4_test_role has restricted access and cannot perform SELECT, INSERT, UPDATE, or DELETE operations on the members table.

The inspection also identified security concerns, including the use of a superuser account by the application and the absence of expected application roles. These findings provided recommendations for improving database security and enforcing the principle of least privilege.

Overall, the activity helped the group understand the importance of proper database access control, restricted privileges, and regular security verification in protecting application data.